

Análise de Lacunas — CoteCerto V10

Table of Contents

Análise de Lacunas — cotecerto33 vs Protótipo CoteCerto V10

Data: 12/07/2026 - **Fonte da verdade:** cotecerto_prototipo_v10.html + Handoff TI + Auditoria + Visão Executiva V10

Resumo executivo

Indicador	Valor
Prontidão geral vs V10	~60%
Telas do protótipo	28
Telas funcionais no projeto	21
Telas parciais	2 (Comissões, Renovações)
Telas ausentes/stub	5 (Aprovações, Premiações, Relatórios, área Master/Supervisor dedicada)
Estimativa de ajuste (só GAPs V10)	~51–78 dias úteis (1 dev)
Estimativa completa (GAPs + melhorias + segurança + integridade + testes + Docker)	87–129 dias úteis (≈ 4–6 meses com 1 dev - ≈ 9,5–14 semanas com 2 devs) — ver seção 11

O projeto tem uma **base sólida**: backend Supabase real (39 migrations, RLS, RPCs, cron), autenticação com aprovação de cadastro, e todo o fluxo de venda (lead → cotação → proposta → aceite) funcionando com dados reais. Porém, **o coração da V10 não existe**: hierarquia com superior definido, perfil Supervisor, bifurcação de franquia Individual/Full, desconto multinível com Aprovações e alçada, motor de comissão (20% Master / Elite / CLT) e tutoriais.

1. O que já está pronto — OK

Fluxo de venda (vendedor) — ~90%

Protótipo	Projeto	Status
Início (cockpit)	venda/inicio.tsx	— OK Metas, ranking, atalhos
Atender agora	venda/atender.tsx	— OK Fila de leads + SLA

Novo lead + cotação	venda/novo-lead.tsx	— OK Wizard completo, FIPE/CEP (prêmio simulado , sem API de seguradora)
Pipeline	venda/pipeline.tsx	— OK Kanban
Cotações / comparar	venda/cotacoes.*	— OK Compara prêmios, coberturas editáveis
Propostas	venda/propostas.tsx	— OK
Aceite & transmissão	venda/aceite.tsx	— OK Registra apólice
Extrato	venda/extrato.tsx	— OK
Mensagens prontas	venda/mensagens-prontas.tsx	— OK

Comando — ~90%

Visão geral (KPIs, ranking, export PDF), Leads (filtros, arquivar, redistribuir), Distribuição (regras + simulador de fila) — tudo funcional.

Operação Matriz — ~80%

Franquias (lista + detalhe), Vendedores, Supervisão (presença online), Pipeline geral, Vendas, Estornos, Mensagens, Acessos (aprovação de cadastros, 6 RPCs), Configurações (seguradoras, planos, integrações) — funcionais.

Infra

Login real Supabase, roles (matriz/master/vendedor/franqueado), fluxo cadastro→pendente→aprovação, auditoria de login, presença online, 5 modelos de franquia seedados (Smart, Conecta, Light, Link, Flex), clt_config com tabela progressiva.

Fidelidade visual — — OK idêntica ao protótipo

Verificado: o src/styles/proto.css do projeto é byte a byte o CSS do protótipo V10 (26 variáveis de tema e 430 classes, 100% iguais), e as telas React usam essas classes (85–100% dos classNames por tela). O visual não é um gap — o pendente é funcional. As telas ausentes (Aprovações, xdash etc.) já têm o CSS pronto esperando por elas; a task Q3 (varredura tela a tela) permanece para ajustes finos de comportamento.

2. O que falta — PENDENTE (gaps vs V10)

GAP 1 — Hierarquia e perfil Supervisor - crítico - 8-12 dias

O pilar da V10: “todo usuário tem um superior”. - Enum perfil não tem supervisor (só matriz/master/vendedor/franqueado). - Não existe campo superior_id em profiles/empresas — nenhuma cadeia de reporte. - Classificação de tipo + superior ao

liberar acesso (em Acessos) não existe. - Lista central de usuários em Configurações (“Perfis e usuários”) refletindo a hierarquia não existe. - Área dedicada Master/Supervisor do protótipo (xdash, xacessos + menus escopados) coberta só parcialmente pelo role master.

GAP 2 — Franquia Individual vs Full - crítico - 5-8 dias

- modelos_franquia.tipo é 'franqueada'|'clt'; o protótipo exige 'individual'|'full' (Smart/Conecta/Light/Link/Flex = Individual; Full = com equipe).
- Não existe bifurcação de área: franquias Individual deve receber o **cockpit de vendedor** (sem cadastro de vendedores nem ranking de equipe); Full recebe a área de franqueado completa (equivalente ao isFranqIndividual() do protótipo).
- Role franqueado foi adicionado ao enum (migration 035) mas sem área própria.

GAP 3 — Desconto multinível + Aprovações + alçada - crítico - 10-15 dias

Zero implementado (nenhuma ocorrência de desconto/alçada no código): - Solicitação de desconto adicional dentro da cotação (vendedor CLT, franquias, vendedor de franquias). - Tela **Aprovações** (maprov) — inbox por nível (Matriz, Master, Supervisor, Franqueado Full), com aprovar / contrapropor / negar / escalar. - Roteamento ao superior imediato + escalonamento até a Matriz com trilha auditável persistida. - Política de alçada em Acessos › Personalização geral: % máximo por modelo × seguradora + condições. - Respostas-padrão por seguradora e por solicitante. - “Abrir cotação” para conferência (cotação real somente leitura).

GAP 4 — Motor de comissão - alto - 8-12 dias

- Regra 20% do Master sobre comissão líquida da equipe (incl. renovações): não existe.
- Campanhas **Elite** por faixa: nenhuma ocorrência no código.
- CLT progressiva: clt_config existe no banco, mas sem motor de cálculo aplicado.
- Tela Comissões marcada “EM FORMULAÇÃO” — finalizar.

GAP 5 — Telas incompletas (só esqueleto) - médio - 8-12 dias

- **Premiações** (premiacoes.tsx, 16 linhas — só HTML estático do protótipo): 4-6 d.
- **Relatórios** (relatorios.tsx, 16 linhas — idem): 4-6 d.

GAP 6 — Tutoriais/tours por perfil - médio - 4-6 dias

Não existe nada (matches no código eram falsos positivos de “SLA estourado”). O protótipo tem **3 roteiros** de tour com spotlight (~148 passos, ~111 alvos): vendedor + franquias Individual (~73 passos), Matriz (~54) e grupo Master/Supervisor/Franquia Full (~21), com abertura personalizada por persona — detalhado em MAPA_PROTOTIPO_PERFIS.md §6.

GAP 7 — Renovações (automação) - médio - 3-5 dias

Tela lê dados, mas sem automação de aviso ao vendedor; e renovações precisam alimentar a comissão do Master (GAP 4).

GAP 8 — Pendências do Handoff - médio - incluído nos itens acima

- Normalização CPF/CNPJ por dígitos (reinclusão por documento, hoje por nome).
 - Regra “aprova vs escala” validada no **backend** (não só no front).
 - Cálculo real de prêmio por seguradora (hoje simularCálculo local) — fora do escopo V10 UI/UX, mas registrado.
-

3. Status por perfil — o que cada usuário já tem e o que falta

Corte dos mesmos gaps por tipo de usuário (as 6 experiências do protótipo V10); os totais são os mesmos da seção 4.

Visão geral

Perfil	Pronto	O que já consegue fazer hoje	Principal falta
Vendedor (CLT)	~85%	vender de ponta a ponta	pedir desconto - tutorial
Matriz	~75%	comandar leads, acessos e configurações	Aprovações - política de alçada - motor de comissão
Franquia Individual	~40%	nada como experiência própria (cockpit já existe emprestado do vendedor)	bifurcação no login - desconto ao superior
Master	~30%	usa área de venda + comando genérico	área de grupo escopada (xdash) - 20% da equipe - Aprovações
Franquia Full	~20%	login genérico	área de franqueado com equipe - Aprovações dos vendedores
Supervisor	~5%	nada (perfil não existe no sistema)	tudo: role, área, equipe CLT + franquias diretas

1 - Vendedor (CLT) — ~85% - persona Rafinha

Já funciona: todo o cockpit — Início (metas, ranking), Atender agora (fila + SLA), Pipeline, Novo lead + cotação (FIPE/CEP), Cotações/comparação, Propostas, Aceite & transmissão, Extrato, Mensagens prontas.

Parcial: cálculo do prêmio é simulado no front (sem API de seguradora); comissão progressiva CLT aparece mas não é calculada por motor real.

Falta: botão “Solicitar desconto adicional” na cotação (G3.3) - tutorial do vendedor, ~73 passos (G6.3-4) - notificação do resultado do desconto.

Entregue por: listas 3 e 6. É o perfil que menos depende do projeto — já opera.

2 - Matriz — ~75% - persona Ana

Já funciona: 12 das 17 telas — Visão geral, Leads, Distribuição (com simulador), Franquias, Vendedores, Supervisão (presença), Pipeline geral, Vendas, Estornos, Mensagens, Acessos (aprovação de cadastros), Configurações (seguradoras, planos, integrações).

Parcial: Comissões (“EM FORMULAÇÃO”) - Renovações (sem automação).

Falta: tela **Aprovações** como última instância (G3.4) - classificação de acesso com os 5 tipos e campos condicionais (G1.4) - política de alçada por modelo × 7 seguradoras (G3.5) - lista “Usuários do sistema” com hierarquia (G1.5) - Premiações e Relatórios reais (G5) - motor de comissão (G4) - tutorial da Matriz, ~54 passos.

Entregue por: listas 1, 3, 4, 5 e 6.

3 - Franquia Individual — ~40% - persona Felipe

Situação: a experiência é a mesma do vendedor — e o cockpit do vendedor está pronto. O que não existe é o **caminho até ele**: o sistema não sabe que uma franquia Smart/Conecta/Light/Link/Flex deve cair no cockpit de venda.

Falta: tipo individual|full no modelo (G2.1) - bifurcação no login — equivalente ao isFranqIndividual() (G2.2) - rótulo “Franqueado - individual” no perfil - pedido de desconto roteado ao **superior real** (Master ou Supervisor, não direto à Matriz) (G3.2) - classificação correta no Acessos (G2.5) - tutorial (herda o do vendedor).

Entregue por: listas 1, 2 e 3. Esforço baixo — reaproveita quase tudo do vendedor.

4 - Master — ~30% - persona Douglas

Situação: o role master existe e enxerga as áreas de venda e comando, mas isso **não é** a área do protótipo — falta a visão de grupo escopada.

Falta: dashboard xdash (operação própria + franquias supervisionadas) (G1.6) - os **20% sobre a comissão líquida da equipe**, incl. renovações (G4.2) - fila de Aprovações filtrada pela rede dele (G3.4) - xacessos (acessos da equipe) (G1.6) - superior definido (reporta à Matriz) (G1.1) - escalar pedidos acima da alçada à Matriz (G3.2) - tutorial do grupo, ~21 passos.

Entregue por: listas 1, 3, 4 e 6.

5 - Franquia Full — ~20% - persona Marcelo

Situação: o enum franqueado foi criado no banco (migration 035), mas não há área própria.

Falta: toda a área de franqueado com equipe — cadastro de vendedores da franquia, ranking e acompanhamento (G2.3) - visão de grupo xdash com 0% de override (remunerado pelo modelo) (G1.6) - Aprovações dos pedidos dos **seus** vendedores, com alçada própria e escalonamento ao Master (G3) - vínculo “Vendedor de franquia” na classificação (G1.4) - tutorial do grupo.

Entregue por: listas 1, 2, 3 e 6.

6 - Supervisor (Matriz) — ~5% - persona Paula

Situação: não existe — nem como role no enum, nem como tela, nem como conceito. É o perfil que nasce do zero.

Falta: role supervisor no enum (G1.1) - área de grupo com equipe CLT + franquias diretas (G1.6) - % **personalizável** sobre a equipe (ex.: 15%, configurado na classificação) (G4) - fila de Aprovações do nível supervisor (G3.4) - campos próprios na classificação: comissão modelo Supervisor, royalties, franquias que vai supervisionar (G1.4) - tutorial do grupo.

Entregue por: listas 1, 3, 4 e 6. As 12 telas de grupo são compartilhadas com Master/Franquia Full — construídas uma vez, escopadas por perfil.

Leitura por fase: o que cada perfil ganha

Fase concluída	Vendedor	Matriz	Franq. Ind.	Master	Franq. Full	Supervisor
1 - Hierarquia	—	classificação + usuários	superior definido	xdash/xacessos	xdash	passa a existir
2 - Ind/Full	—	classificação Ind/Full	cockpit correto	—	área com equipe	—
3 - Desconto	pede desconto	Aprovações (última instância)	pede ao superior	aprova/escala	aprova/escala	aprova/escala
4 - Comissão	CLT progressiva real	motor auditável	modelo de franquia	20% da equipe	modelo + Elite	% personalizável
5 - Telas	—	Premiações/Relatórios	—	Premiações/Relatórios do grupo	idem	idem

6 - Renov/Tu toriais	tutorial + avisos	tutorial	tutorial (do vendedor)	tutorial + renov. na comissão	tutorial	tutorial
----------------------------	----------------------	----------	------------------------------	-------------------------------------	----------	----------

4. Cálculo do % de prontidão

Módulo

Fluxo de venda (9 telas)
 Comando (3 telas)
 Operação Matriz (9 telas)
 Comissões + política (20%/Elite/CLT)
 Hierarquia + Supervisor + área Master
 Desconto multinível + Aprovações
 Franquia Individual/Full
 Renovações
 Premiações
 Relatórios
 Tutoriais
Total

5. Cronograma sugerido (1 dev pleno)

Fase	Escopo	Dias úteis
1	Hierarquia + Supervisor + superior_id + classificação em Acessos (GAP 1)	8–12
2	Franquia Individual/Full + bifurcação de área (GAP 2)	5–8
3	Desconto multinível + Aprovações + alçada (GAP 3)	10–15
4	Motor de comissão + finalizar tela Comissões (GAP 4)	8–12
5	Premiações + Relatórios (GAP 5)	8–12
6	Renovações + Tutoriais (GAPs 6–7)	7–11

7	Ajustes finos de UI/UX vs protótipo + QA + testes	5-8
	Total	51-78

≈ **2,5 a 4 meses** com 1 dev - ≈ **5-8 semanas** com 2 devs (fases 1-2 são pré-requisito das 3-4; 5-6 podem rodar em paralelo).

Premissas: dev pleno full-time já familiarizado com React/Supabase; estimativas incluem migrations, RLS e telas. Não inclui integração real de cálculo com seguradoras (dependência externa, sem estimativa).

6. Banco de dados — estrutura atual vs necessária

As mudanças de banco **já estão incluídas** nas estimativas dos GAPs (cada fase contempla migrations + RLS + telas). Detalhamento:

O que o banco já tem — OK

31 tabelas bem estruturadas: empresas, profiles, user_roles (separada, anti-escalada de privilégio), leads/lead_eventos, cotacoes + 6 tabelas satélites, propostas, seguradoras/planos, modelos_franquia, clt_config (progressiva + fator_novas em jsonb), comissao_lancamentos, metas, distribuicao_config, presença online e auditoria de login. RLS por papel (has_role), RPCs security definer, cron de SLA. Arquitetura correta e reaproveitável.

O que falta no banco — PENDENTE

GAP	Mudança necessária no banco
1 - Hierarquia	Adicionar 'supervisor' ao enum perfil; criar superior_id em profiles (hoje não existe — só há empresas.parent_id, 1 nível); reescrever empresas_visiveis() e as policies RLS, que hoje assumem apenas 2 níveis (matriz → empresa) e não suportam a cadeia Vendedor de franquias > Franquia > Master/Supervisor > Matriz
2 - Individual/Full	Enum modelo_tipo é ('franqueada', 'clt') — precisa de ('individual', 'full') ou coluna nova em modelos_franquia; flag de bifurcação de área no perfil/empresa
3 - Desconto multinível	Nenhuma tabela existe. Criar: desconto_politicas (alçada % por modelo × seguradora + condições), desconto_solicitacoes (solicitante, nível atual, % pedido, alvo, status),

4 - Comissão

desconto_trilha (cada passo com autor e timestamp — trilha auditável exigida pelo Handoff), respostas_padrao (por seguradora × solicitante). Regra “aprova vs escala” validada em RPC no servidor, não no front

7 - Renovações

comissao_lancamentos é só um livro-razão crédito/débito por vendedor. Falta: tabela de regras (20% Master sobre a comissão líquida da equipe), campanhas_elite (faixas), motor que consome o clt_config (existe mas nada o usa), e vínculo renovação → comissão do Master

8 - Handoff

Job/trigger de aviso automático (pg_cron já existe no projeto — é estender)

Normalizar empresas.documento por dígitos + índice único (detecção de reinclusão por CPF/CNPJ, hoje por nome)

Parcela de banco dentro dos GAPs: **~15–20 dias** dos 51–78 totais (migrations, RLS, RPCs).

7. Ordem de ataque recomendada

1. **GAP 1 (hierarquia)** primeiro — tudo na V10 depende de “quem reporta a quem”.
 2. **GAP 2 (Individual/Full)** — muda o enum e a experiência de login da franquia.
 3. **GAP 3 (desconto/Aprovações)** — maior entrega visível da V10.
 4. **GAP 4 (comissão)** — remove as planilhas; depende da hierarquia.
 5. GAPs 5–7 em paralelo/sequência conforme equipe.
-

8. Melhorias técnicas recomendadas (saúde do projeto)

Avaliação da stack: React 19 + TanStack Start/Router, Tailwind v4 + shadcn/ui, react-query, zod e Supabase self-hosted — combinação moderna e adequada ao projeto. **Não recomendamos trocar nada;** o que precisa melhorar é o entorno, não a stack.

#	Melhoria	Por quê	Estimativa
1	Testes automatizados (Vitest) — setup + cobertura das regras de negócio (alçada,	Hoje não existe nenhum teste. As regras da V10 são exatamente o tipo de lógica que quebra em silêncio	5–8 d

	escalonamento, 20% Master, CLT progressiva)		
2	Versionamento de migrations (Supabase CLI) — substituir aplicação manual no SQL Editor	39 arquivos SQL aplicados na mão, sem controle do que foi aplicado; risco de ambientes dessincronizados	2–3 d
3	Tipos gerados do banco (supabase gen types typescript)	Queries hoje retornam any; typegen dá segurança de tipo de ponta a ponta	1 d
4	Refatorar arquivos gigantes — novo- lead.tsx (1.339 linhas), acessos.tsx (1.205), configuracoes.ts x (714) em componentes/hoo ks	Reduz muito o custo dos GAPs 1– 3, que mexem justamente nessas telas	4–6 d
5	Remover resíduo do protótipo — proto-pages.json (279 KB) e ProtoPage	Infla o bundle; sai naturalmente quando Premiações/Relat órios virarem telas reais	incluído no GAP 5
6	Regras de negócio no servidor — alçada, comissão e validações em RPCs/triggers, não no front	Exigência explícita do Handoff TI	incluído nos GAPs 3–4
7	CI + ambiente de homologação — GitHub Actions (lint, typecheck, testes) + Supabase de staging	Mexer em RLS/hierarquia sem staging é arriscado: uma policy errada derruba a	2–3 d

visibilidade de
todos em
produção

Total adicional

14-21 d

Impacto no cronograma

Itens 2, 3 e 7 (**5-7 dias**) devem vir **antes** da Fase 1 — são pré-requisito de segurança para mexer em RLS e hierarquia. Itens 1 e 4 podem rodar em paralelo com as primeiras fases ou logo antes delas.

Cenário	Total
Só os GAPs V10	51-78 dias úteis
GAPs V10 + melhorias técnicas	65-99 dias úteis ($\approx$ 3-5 meses com 1 dev - $\approx$ 7-10 semanas com 2 devs)

O investimento de ~2-4 semanas em saúde técnica se paga dentro do próprio projeto: os GAPs 1-4 mexem em regras críticas de dinheiro (comissão, desconto) e visibilidade (RLS) — fazer isso sem testes, staging e migrations versionadas custaria mais caro em retrabalho.

9. Segurança da API Supabase (auditoria)

O que está correto — OK

- RLS habilitado em todas as 31 tabelas; tabelas de negócio (leads, clientes, oportunidades, propostas, cotações) escopadas por `empresas_visiveis()` + `has_role()`.
- `user_roles` em tabela separada — padrão anti-escalada de privilégio correto.
- Functions security definer com `set search_path` fixado (evita hijack de schema).
- Chave `service_role` usada apenas em server functions (TanStack `createServerFn`) — não vai ao bundle do cliente. Anon key no bundle é publishable (aceitável).
- Auditoria de tentativas de login (`login_audit`, migration 039).

Vulnerabilidades encontradas — atenção

#	Achado	Severidade	Correção	Estimativa
S1	Views ignoram RLS: <code>vendedor_conta_corrente_saldo</code> , <code>v_franquia_kpis</code> , <code>v_vendedor_kpis</code> , <code>v_user_prese</code>	Alta	<code>alter view ... set (security_invalidator = true)</code> + revisar policies das tabelas-base	1 d

	nce criadas sem security_invo ker = true e com grant select to authenticate d — qualquer vendedor logado lê saldo de comissão e KPIs de todos via REST			
S2	Insert aberto em empresas: policy with check (true) permite qualquer autenticado criar empresas direto no endpoint, fora da RPC cadastrar_franquia	Alta	Restringir insert a service_role/ RPC; remover policy permissiva	0,5 d
S3	comissao_lancamentos mal escopada: master/franqu eado leem lançamentos de todos (sem recorte de equipe); insert direto na tabela com valor arbitrário, sem validação no banco	Alta	Escopar select pela rede do usuário; mover insert para RPC com validação de valor/origem	1-2 d
S4	lead_eventos insert with check	Média	Restringir à empresa	0,5 d

	(true): qualquer autenticado forja eventos no histórico de qualquer lead		visível + RPCs existentes	
S5	Sem rate limiting: RPC registrar_ten tativa_login executável por anon sem limite (flood); limites de GoTrue/Kong não estão no repositório (self-hosted — confirmar na infra)	Média	Rate limit no proxy (nginx/Cloudfl are) + limites GoTrue + CAPTCHA em login/cadastro ; throttle na RPC (ex.: máx. N registros/IP/ min)	2–3 d
S6	Catálogo exposto a anon: seguradoras, planos (com % de comissão) e pipeline_stag es legíveis sem login	Baixa	Remover grants/polície s de anon onde não for necessário ao fluxo público	0,5 d
S7	Validação de negócio no cliente: valores e transições de status confiam no front em vários fluxos Total segurança	Média	Consolidar em RPCs/triggers (já previsto nos GAPs 3–4)	incluído 6–8 d

Observações

- Itens S1–S3 mexem com **dados financeiros** e devem ser corrigidos **antes de qualquer novo desenvolvimento** — são 2–3 dias de trabalho.

- O rate limiting em Supabase self-hosted não é configurável por SQL: exige ação na infraestrutura (Kong/GoTrue/proxy reverso). Verificar o que já existe no servidor supabase-cotecerto.sandboxallcom.com.
- Quando os GAPs 1–3 reescreverem empresas_visiveis() e criarem as tabelas de desconto, **toda policy nova deve nascer com teste** (ver melhoria 1 da seção 8).

10. Integridade de dados (validação no banco)

Auditoria de tipos, limites e constraints das 31 tabelas.

O que está correto — OK

- Dinheiro em numeric(14,2) (tipo certo — não float), percentuais em numeric(6,3).
- Status controlados por enum ou check in (...) (lead_status, cotacao_status, tipo crédito/débito, presença etc.); metas.mes between 1 and 12.
- Uniques corretos nos catálogos (seguradoras, planos, motivos de perda) e anti-duplicidade em user_roles, metas e proposta×cotação.

Problemas encontrados — atenção

#	Achado	Risco	Correção	Estimativa
D1	68 colunas text sem limite de tamanho — nenhum varchar(n) ou check length() no banco inteiro. Qualquer autenticado pode gravar textos gigantes (o text do Postgres aceita até ~1 GB) em nome, descrição, mensagens, user_agent etc. via REST	Abuso de storage / DoS / UI quebrada	check (char_length(col) <= n) por categoria: nomes 150, e-mails 254, descrições 2.000, conteúdo de mensagens 5.000, user_agent 500	1–2 d
D2	Valores monetários sem validação de	Lançamento de comissão negativa/absurda direto na	check (valor > 0), check (perc between 0 and 100)	0,5 d

	faixa — comissao_lan camentos.val or, leads/propost as.valor e cotacao_pre mios.premio aceitam negativo e zero; perc_comissa o_padrao sem check 0-100	API		
D3	Sem validação de formato nem unicidade em documentos — email, documento (CPF/CNPJ), cep, telefone, placa são text livre; não há unique em empresas.doc umento, clientes.docu mento nem profiles.email → duplicatas possíveis (o Handoff já exigia normalização por dígitos)	Cadastros duplicados, dados sujos	Normalizar por dígitos (trigger), check de formato (email regex, CPF/CNPJ 11/14 dígitos, CEP 8) + unique index; exige limpeza dos dados existentes antes	1,5–2 d
D4	10 colunas jsonb sem validação de schema — clt_config.pro gressiva, condições de modelos, distribuicao_	Regras de comissão corrompidas	check com jsonb_typeof/ estrutura mínima ou validação na RPC	1 d

	config etc.: um JSON malformado salvo pela Matriz quebra o cálculo silenciosament e			
D5	Front quase sem validação — zod está instalado mas não é usado nos formulários (cadastro, novo lead); só 2 maxLength em todo o src; as máscaras (masked-input) formatam mas não validam	UX ruim + dependência total do banco	Schemas zod por formulário espelhando as constraints do banco	2–3 d
	Total integridade			6–8,5 d

Nota: a validação no **banco** é a que conta — o front pode ser contornado chamando a API REST direto. Por isso a ordem correta é: constraints no banco primeiro (D1–D4), zod no front depois (D5), espelhando as mesmas regras. Ambos devem entrar **antes** dos GAPs 3–4, que criam exatamente as tabelas mais sensíveis (desconto e comissão) — as tabelas novas já nascem validadas.

11. Cronograma consolidado (GAPs + melhorias + segurança + integridade)

Cenário	Total
Só GAPs V10	51–78 dias úteis
+ melhorias técnicas (seção 8)	65–99 dias úteis
+ correções de segurança (seção 9)	71–107 dias úteis
+ integridade de dados (seção 10)	77–115 dias úteis
+ suíte completa de testes (lista T do plano: E2E, RLS, integração, carga)	82–123 dias úteis

+ containerização Docker (lista K do plano: front, compose, CI, deploy)

87–129 dias úteis (≈ 4–6 meses com 1 dev - ≈ 9,5–14 semanas com 2 devs)

Pré-obra recomendada (antes da Fase 1 dos GAPs): segurança S1–S3 (2–3 d) + integridade D1–D4 (4–5,5 d) + migrations versionadas/typegen/staging (5–7 d) ≈ **2–3 semanas** que protegem todo o resto do projeto.

12. Checklist pré-início (fora do código — confirmar antes do dia 1)

Itens que **não estão no repositório** e precisam de resposta antes de iniciar o desenvolvimento:

#	Item	O que verificar	Por quê
C1	Revogar acessos do dev anterior	Trocar senha do admin seed (desenvolvimento @suppercerto.com.br), rotacionar service_role key e senha do banco, revisar acessos ao servidor supabase-cotecerto.sandbox allcom.com, ao GitHub e à conta Lovable	O dev antigo saiu; todas as credenciais que ele teve devem ser consideradas comprometidas
C2	Backup do banco	Existe rotina de backup do Supabase self-hosted? Testar um restore	Com o sistema fora de uso (C4), a criticidade cai, mas segue recomendado antes do go-live
—	Ambiente de desenvolvimento	— OK Definido (13/07/2026) : Supabase local via CLI (Docker) para desenvolvimento; o self-hosted atual segue como produção; .env.example criado na raiz documentando as variáveis	—
C3	Drift banco × migrations	Comparar pg_dump --schema-only do	Migrations foram aplicadas

		banco real com as 39 migrations do repositório	manualmente — o banco de produção pode ter divergido do que está versionado
C4	Sistema já está em uso?	— OK Respondido (13/07/2026): NÃO está em uso. Modo agressivo liberado — sem plano de migração de dados; banco de produção pode ser recriado pelas migrations. Backup segue recomendado (C2)	—
C5	Onde roda o front?	Não há config de deploy no repositório (Docker, Vercel etc.) — descobrir como o app é publicado hoje e onde ficam as variáveis de ambiente (SELF_SUPABASE_SERVICE_ROLE_KEY etc.)	Sem isso não há como publicar as correções
C6	Manter ou desconectar o Lovable?	— OK Decidido (13/07/2026): manter por ora, desconexão manual mais tarde. Até lá: main sempre funcional, sem reescrita de histórico, trabalho de agente em branches + merge	—
C7	Validar o protótipo V10 como escopo final	Confirmar com a diretoria/stakeholders que o V10 (jun/2026) é a versão a	Evita retrabalho se a política de comissão ainda estiver em discussão

		implementar, incluindo os percentuais (20% Master, faixas Elite)	
C8	LGPD / retenção	O banco guarda CPF/CNPJ, IP e user_agent (login_audit); definir política de retenção e acesso	Dados pessoais em produção implicam obrigações legais

Estimativa das verificações: **2-4 dias** (C1 e C2 são imediatos e prioritários), em paralelo com a pré-obra.